AWS Attack Path Review

Account **111122223333** · Run **2026-10-13** · Prepared for Ritvik Indupuri

Caller: user/ir-team (ReadOnlyAccess + SecurityAudit) · 17 regions · Read-only: only Describe/List/Get/Lookup calls. No AWS calls were made to build this report. All times EDT (UTC-4). Access key IDs are shown as last-4 only and marked [MASKED].

1. Critical: signs of compromise

OVERALL SEVERITY: CRITICAL

- **Logging is off and the archive is gone.** CloudTrail management-events stopped 2026-06-09 16:13:25; its S3 log bucket no longer exists (NoSuchBucket). Last good delivery 2025-12-14.
- **GuardDuty deleted, Security Hub off.** ops-admin deleted the GuardDuty sensor 2026-10-05 21:20 from 198.51.100.20. No sensor in any of 17 regions.
- **Look-alike admin users with standby keys.** On 2026-06-09, admin keys were minted for backup-svc-b, backup-admin-user, backup-svc-a, svc-automation (11:09:52), sys-backup-svc (11:20), svc-monitor (14:25), support-agent (14:45), obj-backup-svc (16:13, 17:39). **None were ever used.**
- **scanner-user: likely persistence.** Created Jun 7. Old key …CCCC last used on IAM **Jun 9 11:25**, inside the key-minting burst. Active key …AAAA never used. Holds AdministratorAccess + ScannerUserPolicy (StopLogging, CreateUser, CreateAccessKey).
- **Exfil markers.** example-staging-bucket-111122223333 holds 41 stolen-audit-data/*.json objects (written Jun 9 11:21) plus RED-TEAM-ASSESSMENT-COMPLETE and COMPROMISE-COMPLETE-OPSADMIN markers. Contents not read.
- **ops-admin is active today.** Admin + CloudTrail + GuardDuty full access; DeleteStack on 5 lab-fix-* stacks at 10:21–10:22 today from 203.0.113.10.

Caveat. Markers, Simulated* tags and shared owner IPs suggest an owner-run red-team exercise. Even so, the account is open now with zero monitoring, so severity stays CRITICAL until Ritvik confirms (Section 6).

2. Executive summary

Bottom line

- **Anyone holding one of 12 admin keys owns the account**, and nothing would record it.
- **Six attack paths found:** 3 LIVE today, 2 latent (need admin first), 1 low (recon only).
- **Five non-admin users can make themselves admin** in one IAM call (audit-reader, lab-test-user, app-user-1, app-agent, scanner-user).
- **One outside identity** (a Google account) can read every S3 bucket via a trailing-dot look-alike role.

Path scorecard

Path	Name	Severity	Status	Top fix
P1	Leaked admin key → full admin	CRITICAL	LIVE	Deactivate never-used admin keys
P2	Non-admin key → admin by escalation	CRITICAL	LIVE	Strip IAM write from lab / app-pilot / scanner-user
P3	Google identity → read all S3	HIGH	LIVE	Delete trailing-dot role
P4	Admin → public no-auth backdoor	HIGH	NEEDS ADMIN	Delete /analyze API
P5	Admin/scanner-user → network or S3 exposure	MEDIUM	NEEDS ADMIN	Account BPA on; remove open SGs
P6	Any admin → recon role	LOW	NEEDS ADMIN	Condition or delete RiskAnalyzerRole

Key numbers

- 20 IAM users · **0 with MFA** · 27 access keys (26 active) · root has an access key (root MFA on)
- **12 users with AdministratorAccess**; 12 admin keys never used (11 on 9 look-alike users + scanner-user …AAAA)
- 51 roles · no wildcard or cross-account trusts · 2 Google-federated roles
- No EC2, Lambda, ECS or EKS · 6 unattached SGs open to 0.0.0.0/0 · 4 private S3 buckets · account-level BPA **not** set
- Monitoring: CloudTrail off · GuardDuty off · Security Hub off (all 17 regions)

First three moves (recommendations; each needs Ritvik's approval)

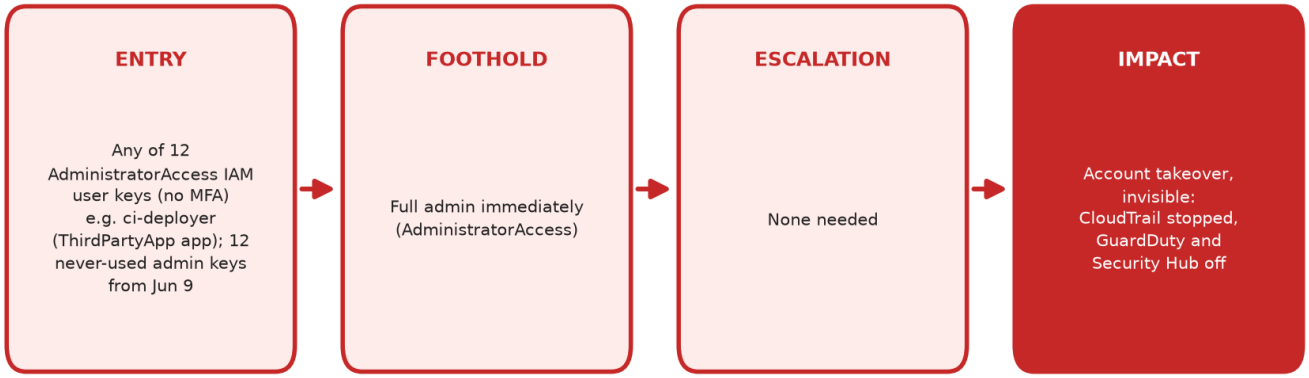
- **Restore visibility:** new private log bucket, restart the trail, GuardDuty in all regions.
- **Deactivate the 12 never-used admin keys** (no business impact; they were never used).
- **Remove escalation** from AuditReadOnlyPolicy, app-pilot IAMFullAccess and scanner-user's inline policy.

3. Attack paths

Each diagram reads left to right: **Entry → Foothold → Escalation → Impact**. Color = severity (**red** critical, **orange** high, **amber** medium, **blue** low). **LIVE** = exploitable today with one credential/token. **NEEDS ADMIN** = attacker must first reach admin (P1/P2).

P1 Leaked admin key → full admin

CRITICAL **LIVE**



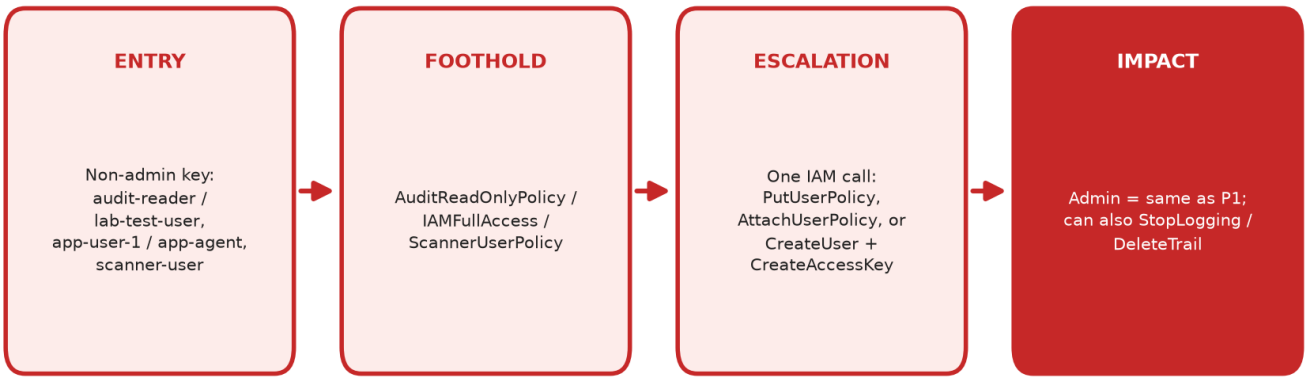
Evidence

- 12 users hold AdministratorAccess via long-lived keys; **none have MFA**.
- Never-used Jun 9 keys: backup-svc-a, support-agent, backup-admin-user (2), backup-svc-b (2), obj-backup-svc (2), svc-automation, svc-monitor, sys-backup-svc, scanner-user …AAAA.
- Riskiest live key: ci-deployer …BBBB, held by the ThirdPartyApp app (203.0.113.50, UA thirdpartyapp/1.0.0), last used Oct 6.
- ops-admin …DDDD used today 10:22 (admin + CloudTrail + GuardDuty full access).
- No logging means a takeover would be invisible.

Sources: inventory/summary.md, iam_users.json, incident report facts 4, 6, 7.

P2 Non-admin key → admin by escalation

CRITICAL LIVE



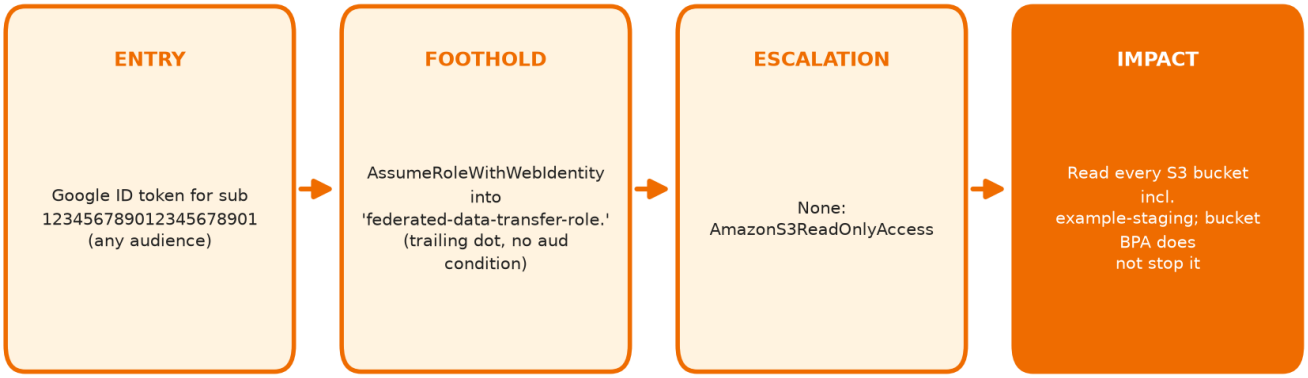
Evidence

- **audit-reader, lab-test-user**: AuditReadOnlyPolicy v3 (despite the name) allows iam:PutUserPolicy, CreateRole, Put/AttachRolePolicy, PassRole (CFN/Lambda), cloudtrail StopLogging / DeleteTrail.
- **app-user-1, app-agent**: IAMFullAccess → attach AdministratorAccess to self. app-user-1 keys last used Sep 28 (iam).
- **scanner-user**: ScannerUserPolicy allows CreateUser, CreateAccessKey, AttachUserPolicy, PassRole (redundant with its AdministratorAccess).
- One API call reaches admin; attacker can then also blind logging.

Sources: identity-findings.md, Identity Mapper, leads-scanner-testuser-gcprole.md (policy JSON).

P3 Google identity → read all S3

HIGH LIVE



Evidence

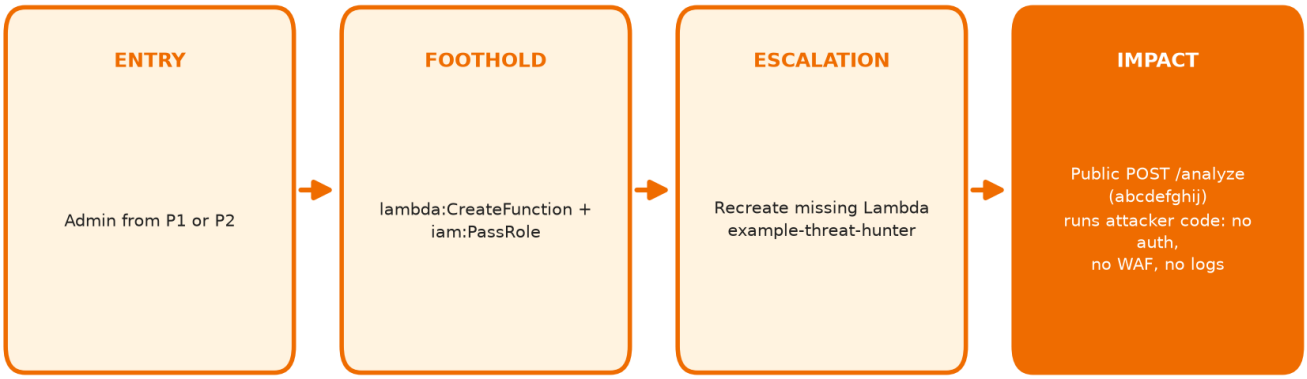
- Role **'federated-data-transfer-role.'** (trailing dot) trusts accounts.google.com, condition **sub = 123456789012345678901 only, no aud**.
- Any Google ID token for that subject, minted for any audience, can be exchanged via AssumeRoleWithWebIdentity.
- AmazonS3ReadOnlyAccess → reads every bucket incl. example-staging. Bucket BPA does not block this.

- Never used: RoleLastUsed empty; 0 AssumeRoleWithWebIdentity events in 90 days, all 17 regions. Verdict: benign 2025 leftover, but still live.

Sources: iam_roles.json (call 007), leads-raw-gcprole.json, Identity Mapper.

P4 Admin → public no-auth backdoor

HIGH NEEDS ADMIN



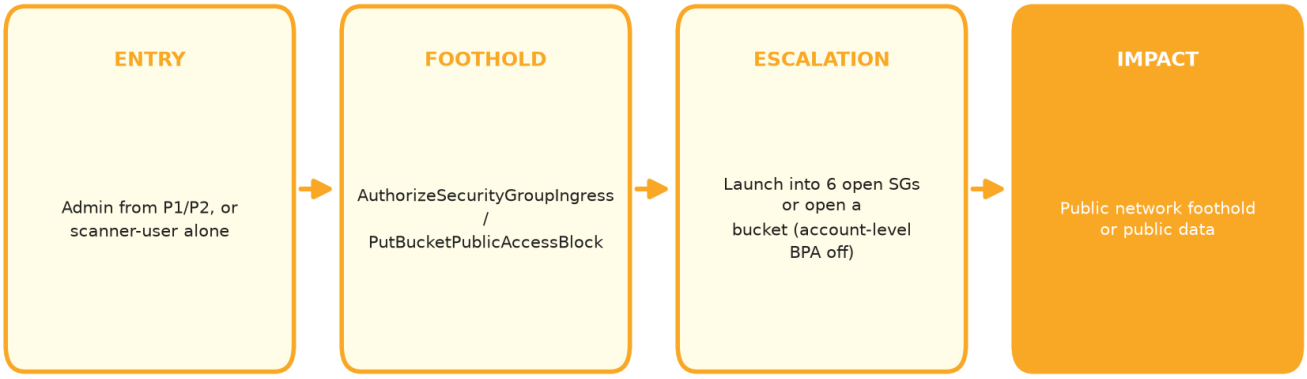
Evidence

- REST API **abcdefghij** 'example-threat-hunting-api' (us-east-1, EDGE, stage prod): POST /analyze, auth NONE, no API key, no WAF, no access logs, no resource policy.
- Integration: AWS_PROXY to Lambda **example-threat-hunter**, which **does not exist** (E002) → currently dead.
- Anyone with CreateFunction + PassRole recreates that name and gets a public, unauthenticated, unlogged entry point.

Sources: exposure/findings.md, commands.log E001/E002.

P5 Admin/scanner-user → network or S3 exposure

MEDIUM NEEDS ADMIN



Evidence

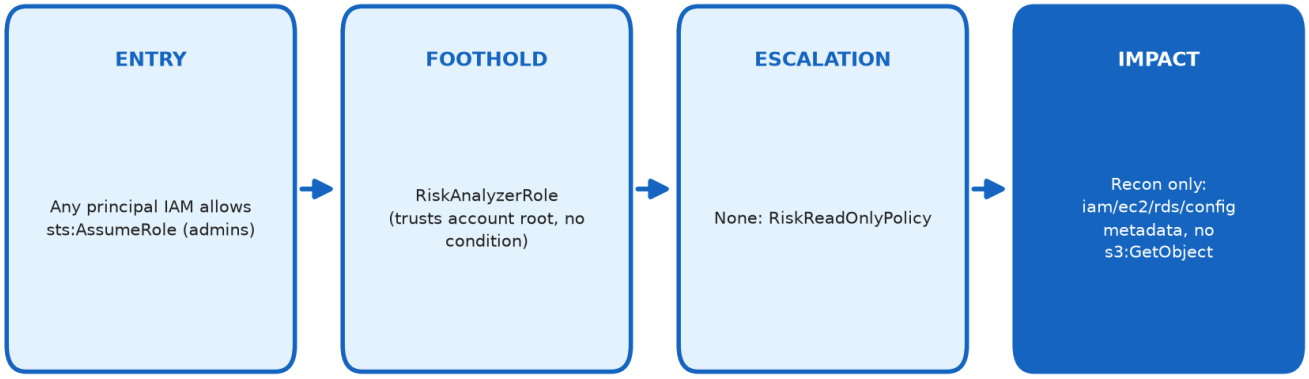
- 6 SGs open to 0.0.0.0/0, none attached today (22, 80, 3389, 5044, 5601, 9200). launch-wizard-3 would expose 22/9200/5601/5044.

- Account-level S3 Block Public Access **not configured**; one PutBucketPublicAccessBlock + policy makes a bucket public.
- **scanner-user alone** can do this (AuthorizeSecurityGroupIngress, PutBucketPublicAccessBlock), no escalation needed.

Sources: network.json, s3.json, inventory/summary.md.

P6 Any admin → recon role

LOW NEEDS ADMIN



Evidence

- RiskAnalyzerRole trusts arn:aws:iam::111122223333:root with an **empty condition**.
- RiskReadOnlyPolicy: iam/ec2/rds/config read, s3:GetBucket*, **no s3:GetObject** → recon hop only.
- Adds a second identity to hide behind, not new power.

Sources: iam_roles.json, identity-findings.md (I004).

4. Ranked fixes (recommendations only)

Nothing was changed in AWS. Score = (live paths cut × impact) / effort. Every row needs Ritvik's explicit approval. CIS = CIS AWS Foundations Benchmark v3.0 control; MITRE = ATT&CK technique the fix disrupts.

#	Fix	Cuts	Effort	CIS	MITRE ATT&CK
1	**Deactivate never-used admin keys** (12 keys on 10 users incl. scanner-user ...AAAA). Deactivate first to keep evidence; delete after review. Hold ops-admin, ci-deployer, ir-team until Ritvik decides.	P1; entry to P4/P5	Low	1.12, 1.13, 1.16	T1078.004, T1098.001
2	**Strip escalation**: (A) AuditReadOnlyPolicy: drop AuditRemediation statement (PutUserPolicy, CreateRole, AttachRolePolicy, PassRole, CFN write, StopLogging, DeleteTrail). (B) app-user-1/-agent: replace IAMFullAccess with least privilege. (C) scanner-user: remove ScannerUserPolicy + AdministratorAccess.	P2	Medium	1.15, 1.16	T1098.003, T1136.003, T1562.008
3	**Delete trailing-dot Google role**; if Storage Transfer is still needed keep only the non-dotted role with both aud and sub conditions.	P3	Low	1.20 (Access Analyzer)	T1078.004, T1530
4	**Turn monitoring back on**: new private, versioned log bucket; restart management-events with log file validation; GuardDuty in all 17 regions; subscribe Security Hub.	Blindness after any P1/P2	Medium	3.1, 3.2, 4.16	T1562.008, T1562.001
5	**Close latent public entry**: delete API abcdefghij (or POST /analyze + stage); account-level S3 BPA (all four); delete/tighten 6 open SGs.	P4, P5	Low to medium	2.1.4, 5.2	T1190, T1530
6	**Harden leftover identity edges**: condition or delete RiskAnalyzerRole trust; MFA on any human/break-glass principals; move ci-deployer/ThirdPartyApp to a role with short-lived creds.	P6; residual P1	Low to medium	1.10, 1.14	T1580, T1078.004
+	**Root access key**: generate credential report, then delete the root key (root MFA already on).	Residual P1	Low	1.4	T1078.004
+	**Stale CodeBuild schedules**: disable RunProwlerDaily and prowler-schedule (+ their 2 scheduler roles), or recreate ProwlerScans on purpose.	Squatting risk	Low	—	T1053 (Scheduled Task/Job)

Path → fix map

- P1 LIVE → 1, then 4 and 6
- P2 LIVE → 2
- P3 LIVE → 3
- P4 LATENT → 1 + 5
- P5 LATENT → 1 + 2C + 5
- P6 LOW → 6

Note: Fix Prioritizer said delete keys; Incident Responder said deactivate, do not delete. This report recommends deactivating first to preserve evidence.

5. Incident findings (read-only)

scanner-user

SUSPICIOUS · likely persistence

- Created 2026-06-07 18:26. No MFA, no console, no groups.
- Key …CCCC (now Inactive) last used **Jun 9 11:25 on IAM**, during the look-alike admin key burst.
- Key …AAAA active, created Jun 9 11:09:37, **never used** → standby backdoor pattern.
- AdministratorAccess + ScannerUserPolicy: CreateUser, CreateAccessKey, AttachUserPolicy, StopLogging, guardduty UpdateSensor, AuthorizeSecurityGroupIngress, PutBucketPublicAccessBlock.
- Creator and CCCC actions not provable: events are older than 90-day history and trail logs are gone.

June 9 look-alike admin keys

SUSPICIOUS · never used

- svc-automation 11:09:52 · sys-backup-svc 11:20 · svc-monitor 14:25 · obj-backup-svc 16:13 and 17:39 (plus backup-svc-b, backup-admin-user, backup-svc-a, support-agent).
- obj-backup-svc user created 16:13:32, **7 seconds after StopLogging**.
- No activity by any of them in the 90-day Event History.

Monitoring disabled

CONFIRMED

- CloudTrail stopped Jun 9 16:13:25; archive bucket aws-cloudtrail-logs-…-4d43b81d is gone (NoSuchBucket).
- Who stopped it is **not determinable** (outside the 90-day window).
- GuardDuty deleted Oct 5 by ops-admin; Security Hub not subscribed.

ops-admin

OPEN QUESTION · active today

- Created Jun 9 14:18. Admin + S3, CloudTrail and GuardDuty full access.
- Sep 13–24: ran app-pilot sandbox/QA stacks, briefly made a public test bucket.
- **Oct 5 21:20: deleted GuardDuty** (198.51.100.20). Oct 11: built and tore down a lab lab incl. a wildcard-admin role (203.0.113.10).
- **Today 10:21–10:22: DeleteStack on 5 lab-fix-* stacks** (203.0.113.10, aws-cli/2.0.30 Windows).

ci-deployer (ThirdPartyApp)

OPEN QUESTION · full admin

- Created Oct 2 17:50 by root (console, 203.0.113.60); AdministratorAccess + key …BBBB.
- Used only from 203.0.113.50, UA thirdpartyapp/1.0.0 (GetCallerIdentity, ValidateTemplate); last used Oct 6.

lab-test-user

BENIGN · over-permissioned

- Owner test user, created by root Oct 11 15:22 from 203.0.113.10.
- 409 events Oct 11, nearly all read-only; 0 PutUserPolicy, 0 StopLogging since Oct 11.
- Concern: 'ReadOnly' policy can escalate to admin (P2); key still active.

federated-data-transfer-role. (trailing dot)

BENIGN · 2025 leftover

- Created 2025-04-22, 3 minutes before the correct role; never used.
- Still a live path (P3) until deleted.

CodeBuild StartBuild calls this morning

BENIGN · stale schedules

- Old EventBridge Scheduler schedules **RunProwlerDaily** and **prowler-schedule** (2025, every 5 min).
- Target project **ProwlerScans does not exist** → ResourceNotFoundException, no build, no code ran.
- Chain is scheduler.amazonaws.com only; no human principal.

Unverified: contents of stolen-audit-data JSON and whether data left the account (no S3 data events); exfil bucket CreationDate 2026-07-10 vs objects dated Jun 9; root key last-used date.

6. Decisions needed from Ritvik

Nothing changes in AWS until these are answered. Q1–Q3 decide between "exercise cleanup" and "external compromise".

#	Question	Why it matters / what follows
1	**Is ops-admin a sanctioned red-team tool?**	It deleted GuardDuty on Oct 5 and CloudFormation stacks today (10:21–10:22). If yes: detach CloudTrail/GuardDuty/Admin when done. If no: deactivate …DDDD now.
2	**Was 203.0.113.10 you?**	ops-admin used it on Oct 11 (and today). Root console logins and lab-test-user creation also came from it.
3	**Is ci-deployer (ThirdPartyApp, full admin, last used Oct 6) still needed?**	If yes: scope it down and move to short-lived creds. If no: deactivate …BBBB.
4	**Do you own the other IPs?**	198.51.100.20 (ops-admin, GuardDuty delete), 203.0.113.60 (root, created ci-deployer), 198.51.100.70 (root, Linux, Sep 5), 203.0.113.50 (ThirdPartyApp).
5	**Do you know the scanner-user user?**	If not, treat as persistence: approve deactivating …AAAA and removing its policies.
6	**Approve the containment order?**	Recommended: (1) restore logging + GuardDuty, (2) deactivate 12 dormant admin keys, (3) strip escalation policies, (4) delete trailing-dot role, (5) close /analyze, BPA, SGs.
7	**Preserve and inspect evidence?**	Approve versioning + forensic copy of example-staging-bucket, and reading the 41 stolen-audit-data JSON objects.
8	**Is lab-test-user testing finished?**	If yes, deactivate its key and fix AuditReadOnlyPolicy (also attached to audit-reader).

7. Changes since the baseline

Baseline: /workspace/aws-attack-paths/report.md (2026-10-13 ~09:50, 4 regions).

New or sharper in this run

- **Coverage 4 → 17 regions.** The 13 new regions hold only default VPCs; no resources or sensors.
- **Escalation newly confirmed** for audit-reader / lab-test-user (AuditReadOnlyPolicy) and scanner-user (ScannerUserPolicy). Baseline could not read policy docs.
- **P3 now a ranked live path:** trailing-dot Google role has no aud condition.
- **P4 clarified:** /analyze backs onto a Lambda that no longer exists (dangling, re-creatable).
- **Key last-used data:** 12 admin keys never used; ci-deployer key created Oct 2, used Oct 6.
- **Attribution detail:** GuardDuty deleted by ops-admin Oct 5; trail stopped Jun 9 16:13; log bucket missing.
- **ops-admin activity after the baseline:** DeleteStack at 10:21–10:22 today.
- Private manual RDS cluster snapshot found (us-east-2); no users have console access; only one inline user policy (scanner-user).
- This morning's CodeBuild StartBuild alerts traced to stale schedules (benign).

Unchanged

- User count (20), the 12-user admin set, role trusts, 6 open SGs, 4 buckets, 2 secrets, unauthenticated API, root access key, and CloudTrail/GuardDuty/Security Hub status.

Removed

- Nothing.

Gaps still open

- No credential report; call 002 output not saved (003 is identical rerun); call 010 hit the 100-call cap (rerun in 012–014).
- Identity Mapper I001/I002 reruns are quoted in the appendix (A10, A11; outputs only, rerun scripts were not saved). I003/I004 exist only as room posts.

8. Appendix: key commands and exact outputs

Quoted verbatim from the run logs. Excerpts are cut at JSON boundaries; long lines are wrapped for display only (no characters added or removed). Access key IDs, if present, would be replaced with AKIA…last4 [MASKED]. Commands were run by the team earlier today, not for this report.

A1. Who ran the scan

inventory/commands/001.md

Command (relevant lines of the script, verbatim)

```
ident=await call_boto3(service_name='sts',operation_name='GetCallerIdentity')
```

Output (excerpt)

```
"id": "111122223333", "arn": "arn:aws:iam::111122223333:user/ir-team"
```

A2. CloudTrail trail status (us-east-2)

inventory/commands/012.md

Command (relevant lines of the script, verbatim)

```
            s=await c('cloudtrail','GetTrailStatus',rg,Name=t['TrailARN'])
```

Output (excerpt)

```
"trails_home_here": [{"name": "management-events", "multi": true, "org": false, "bucket": "example-cloudtrail-logs-111
122223333-4d43b81d", "logging": false, "latest_delivery": "2025-12-15T00:40:38.725000+00:00", "stop_time": "2026-06-09
T20:13:25.407000+00:00"}]
```

A3. GuardDuty and Security Hub (us-east-2)

inventory/commands/012.md

Command (relevant lines of the script, verbatim)

```
    db,cl,sn,csn,sec,rest,http,ct,gd,sh=await asyncio.gather(c('rds','DescribeDBInstances',rg),c('rds','DescribeDBClus
ters',rg),c('rds','DescribeDBSnapshots',rg,SnapshotType='manual'),c('rds','DescribeDBClusterSnapshots',rg,SnapshotType
='manual'),c('secretsmanager','ListSecrets',rg),c('apigateway','GetRestApis',rg),c('apigatewayv2','GetApis',rg),c('clo
udtrail','DescribeTrails',rg),c('guardduty','ListSensors',rg),c('securityhub','DescribeHub',rg))
        x=await c('guardduty','GetSensor',rg,SensorId=d); gds.append({'id':d,'status':x.get('Status',x)})
```

Output (excerpt)

```
"trails_visible": 1, "ct_err": null, "guardduty": [], "securityhub": "An error occurred (InvalidAccessException) when
calling the DescribeHub operation: Account 111122223333 is not subscribed to AWS Security Hub CSPM"
```

A4. Account-level S3 Block Public Access

inventory/commands/011.md

Command (relevant lines of the script, verbatim)

```
try: acct=await call_boto3(service_name='s3control',operation_name='GetPublicAccessBlock',region_name='us-east-1',para
ms={'AccountId':'111122223333'})
```

Output (excerpt)

```
"account_bpa": {"error": "An error occurred (NoSuchPublicAccessBlockConfiguration) when calling the GetPublicAccessBlo
ck operation: The public access block configuration was not found"}
```

A5. scanner-user user: keys and policies

inventory/commands/005.md

Command (relevant lines of the script, verbatim)

```
users=['app-agent','scanner-user','ir-team','sentinel-user','provenance-svc']
        lu=await c('GetAccessKeyLastUsed',AccessKeyId=k['AccessKeyId'])
```

Output (excerpt)

```
{"user": "scanner-user", "keys": [{"id": "AAAA", "status": "Active", "created": "2026-06-09T15:09:37+00:00", "last_use
d": {"ServiceName": "N/A", "Region": "N/A"}}, {"id": "CCCC", "status": "Inactive", "created": "2026-06-07T22:26:49+00:
00", "last_used": {"LastUsedDate": "2026-06-09T15:25:00+00:00", "ServiceName": "iam", "Region": "us-east-1"}}], "mfa":
 0, "attached": ["AdministratorAccess"], "inline": ["ScannerUserPolicy"], "groups": [], "console": false}
```

A6. Trailing-dot Google role trust

inventory/commands/007.md

Command (relevant lines of the script, verbatim)

```
r=await call_boto3(service_name='iam',operation_name='ListRoles')
    return {'role':n,'path':x.get('Path'),'created':str(x.get('CreateDate')),'trust':x.get('AssumeRolePolicyDocument')
,'attached':[p['PolicyName'] for p in a.get('AttachedPolicies',[])] if 'error' not in a else a,'inline':i.get('PolicyN
ames',i)}
```

Output (excerpt)

```
{"role": "federated-data-transfer-role.", "path": "/", "created": "2025-04-22T21:49:34+00:00", "trust": {"Version": "2
012-10-17", "Statement": [{"Effect": "Allow", "Principal": {"Federated": "accounts.google.com"}, "Action": "sts:Assume
RoleWithWebIdentity", "Condition": {"StringEquals": {"accounts.google.com:sub": "123456789012345678901"}}}]}, "attache
d": ["AmazonS3ReadOnlyAccess"], "inline": []}
```

A7. API Gateway abcdefghij /analyze

commands.log, Exposure Finder E001

Command (relevant lines of the script, verbatim)

```
===== Exposure Finder E001: API Gateway abcdefghij config (us-east-1) =====
aws___run_script: GetRestApi, GetResources, GetStages, GetAuthorizers, GetMethod on restApiId=abcdefghij
```

Output (excerpt)

```
"methods": [{"path": "/analyze", "method": "POST", "auth": "NONE", "apiKey": false, "integration": {"type": "AWS_PROXY
", "uri": "arn:aws:apigateway:us-east-1:lambda:path/2015-03-31/functions/arn:aws:lambda:us-east-1:111122223333:functio
n:example-threat-hunter/invocations", "httpMethod": "POST", "credentials": null}}]
```

A8. Backing Lambda example-threat-hunter

commands.log, Exposure Finder E002

Command (relevant lines of the script, verbatim)

```
===== Exposure Finder E002: Lambda example-threat-hunter (us-east-1) =====
aws___run_script: lambda GetFunction FunctionName=example-threat-hunter
```

Output (excerpt)

```
"return_value": {"exists": false, "error": "An error occurred (ResourceNotFoundException) when calling the GetFunction
 operation: Function not found: arn:aws:lambda:us-east-1:111122223333:function:example-threat-hunter"}
```

A9. CodeBuild project ProwlerScans

Command: incidents/2026-10-13-aws/codebuild-trace.md (call 3); output: codebuild-trace-raw.json

Command (relevant lines of the script, verbatim)

```
3. `codebuild batch-get-projects --names ProwlerScans` -> `{"projects": [], "projectsNotFound": ["ProwlerScans"]}`
```

Output (excerpt)

```
"projects": {"projects": [], "projectsNotFound": ["ProwlerScans"]}
```

A10. Identity Mapper I001 rerun: CloudTrail LookupEvents for ops-admin and ci-deployer

Command: commands.log (I001 entry); output: identity/commands/I001-rerun-output.txt (rerun ~14:0x EDT; rerun script not saved)

Command (relevant lines of the script, verbatim)

```
===== Identity Mapper Call I001 (2026-10-13 10:23 ET) =====
aws___run_script (namespace user-Aws-mcp) code:
LookupEvents us-east-1, Username=ops-admin and Username=ci-deployer, MaxResults=50 each (see identity/commands/I001.md
 for exact script and raw output)
```

Output (excerpt)

```
"return_value": {"ops-admin": [{"time": "2026-09-24T15:33:39+00:00", "name": "DescribeAddresses", "src": "ec2.amazonaw
s.com", "res": []}, {"time": "2026-09-24T15:33:38+00:00", "name": "DescribeNatGateways", "src": "ec2.amazonaws.com", "
res": []}, {"time": "2026-09-24T15:33:37+00:00", "name": "DescribeInstances", "src": "ec2.amazonaws.com", "res": []},
{"time": "2026-09-05T14:30:00+00:00", "name": "DescribeSecurityGroups", "src": "ec2.amazonaws.com", "res": []}, {"time
": "2026-09-05T14:29:59+00:00", "name": "DescribeVpcs", "src": "ec2.amazonaws.com", "res": []}, {"time": "2026-09-05T1
4:29:58+00:00", "name": "GetEventSelectors", "src": "cloudtrail.amazonaws.com", "res": ["management-events"]}, {"time"
: "2026-09-05T14:29:52+00:00", "name": "DescribeSubnets", "src": "ec2.amazonaws.com", "res": []}, {"time": "2026-09-05
T14:29:51+00:00", "name": "DescribeVpcs", "src": "ec2.amazonaws.com", "res": []}, {"time": "2026-09-05T14:29:48+00:00"
, "name": "DescribeSecurityGroups", "src": "ec2.amazonaws.com", "res": []}, {"time": "2026-09-05T14:29:17+00:00", "nam
e": "GetTrailStatus", "src": "cloudtrail.amazonaws.com", "res": ["management-events"]}], "ci-deployer": []}
```

A11. Identity Mapper I002 rerun: role trusts and customer policies

identity/commands/I002-rerun-output.txt (rerun ~14:0x EDT; script not saved, so the verbatim api_calls list is shown as the command record)

Calls made (verbatim api_calls from the output)


```
"api_calls": [{"service": "iam", "operation": "ListRoles", "status": "success", "n_items": {"Roles": 51}}, {"service":
 "iam", "operation": "ListPolicies", "status": "success", "n_items": {"Policies": 35}}, {"service": "iam", "operation"
: "GetPolicyVersion", "status": "success"}, {"service": "iam", "operation": "GetPolicyVersion", "status": "success"},
{"service": "iam", "operation": "GetPolicyVersion", "status": "success"}, {"service": "iam", "operation": "GetPolicyVe
rsion", "status": "success"}, {"service": "iam", "operation": "GetPolicyVersion", "status": "success"}, {"service": "i
am", "operation": "GetPolicyVersion", "status": "success"}, {"service": "iam", "operation": "GetPolicyVersion", "statu
s": "success"}, {"service": "iam", "operation": "GetPolicyVersion", "status": "success"}, {"service": "iam", "operatio
n": "GetPolicyVersion", "status": "success"}, {"service": "iam", "operation": "GetPolicyVersion", "status": "success"}
, {"service": "iam", "operation": "GetPolicyVersion", "status": "success"}, {"service": "iam", "operation": "GetPolicy
Version", "status": "success"}, {"service": "iam", "operation": "GetPolicyVersion", "status": "success"}, {"service":
"iam", "operation": "GetPolicyVersion", "status": "success"}, {"service": "iam", "operation": "GetPolicyVersion", "sta
tus": "success"}, {"service": "iam", "operation": "GetPolicyVersion", "status": "success"}, {"service": "iam", "operat
ion": "GetPolicyVersion", "status": "success"}, {"service": "iam", "operation": "GetPolicyVersion", "status": "success
"}, {"service": "iam", "operation": "GetPolicyVersion", "status": "success"}, {"service": "iam", "operation": "GetPoli
cyVersion", "status": "success"}, {"service": "iam", "operation": "GetPolicyVersion", "status": "success"}, {"service"
: "iam", "operation": "GetPolicyVersion", "status": "success"}, {"service": "iam", "operation": "GetPolicyVersion", "s
tatus": "success"}, {"service": "iam", "operation": "GetPolicyVersion", "status": "success"}, {"service": "iam", "oper
ation": "GetPolicyVersion", "status": "success"}, {"service": "iam", "operation": "GetPolicyVersion", "status": "succe
ss"}, {"service": "iam", "operation": "GetPolicyVersion", "status": "success"}, {"service": "iam", "operation": "GetPo
licyVersion", "status": "success"}, {"service": "iam", "operation": "GetPolicyVersion", "status": "success"}, {"servic
e": "iam", "operation": "GetPolicyVersion", "status": "success"}, {"service": "iam", "operation": "GetPolicyVersion",
"status": "success"}, {"service": "iam", "operation": "GetPolicyVersion", "status": "success"}, {"service": "iam", "op
eration": "GetPolicyVersion", "status": "success"}, {"service": "iam", "operation": "GetPolicyVersion", "status": "suc
cess"}, {"service": "iam", "operation": "GetPolicyVersion", "status": "success"}]
```


Output (excerpt)


```
"federated-data-transfer-role.": {"Version": "2012-10-17", "Statement": [{"Effect": "Allow", "Principal": {"Federated"
: "accounts.google.com"}, "Action": "sts:AssumeRoleWithWebIdentity", "Condition": {"StringEquals": {"accounts.google.c
om:sub": "123456789012345678901"}}}]}

{"Sid": "AuditRemediation", "Effect": "Allow", "Action": ["iam:PutUserPolicy", "iam:DeleteUserPolicy", "iam:CreateRole
", "iam:DeleteRole", "iam:PutRolePolicy", "iam:DeleteRolePolicy", "iam:AttachRolePolicy", "iam:DetachRolePolicy", "clo
udformation:CreateChangeSet", "cloudformation:DescribeChangeSet", "cloudformation:ExecuteChangeSet", "cloudformation:D
eleteChangeSet", "cloudformation:DeleteStack", "cloudformation:DescribeStacks", "cloudformation:CreateStack", "cloudfo
rmation:UpdateStack", "s3:CreateBucket", "s3:PutBucketPolicy", "s3:PutBucketPublicAccessBlock", "s3:PutEncryptionConfi
guration", "s3:PutBucketVersioning", "s3:PutLifecycleConfiguration", "ec2:CreateSecurityGroup", "ec2:DeleteSecurityGro
up", "ec2:AuthorizeSecurityGroupIngress", "ec2:RevokeSecurityGroupIngress", "ec2:AuthorizeSecurityGroupEgress", "ec2:R
evokeSecurityGroupEgress", "ec2:ModifySecurityGroupRules", "rds:ModifyDBInstance", "rds:ModifyDBCluster", "rds:ModifyO
ptionGroup", "rds:ModifyDBParameterGroup", "lambda:UpdateFunctionConfiguration", "lambda:UpdateFunctionCode", "lambda:
PutFunctionConcurrency", "dynamodb:UpdateTable", "dynamodb:PutItem", "dynamodb:DeleteItem", "kms:CreateKey", "kms:Upda
teKeyDescription", "kms:EnableKey", "kms:DisableKey", "kms:PutKeyPolicy", "cloudtrail:CreateTrail", "cloudtrail:Update
Trail", "cloudtrail:StartLogging", "cloudtrail:StopLogging", "cloudtrail:DeleteTrail"], "Resource": "*"}
```